

E-Commerce Brand Impersonation & Chinese SaaS Fraud Funnel

Investigation Reference: SEC-2026-ECOM-005 · Target: Media Galaxy (Altex România) · Date: 16 September 2026

Incident Type: Social Media Phishing / Brand Impersonation	Financial Impact: ~21 EUR (~105 RON)
Target Lure Platform: TikTok Sponsored In-App Ads	Payment Rail: Revolut Virtual Card / BCR Source
Phishing Landing FQDN: mediagalaxy.voetbalshop-nlco.com	Backend C2 SaaS: yiyangsaas.com (Yunnan, CN)
Investigator: @stefanutc1 (Senior Security Engineer)	Remediation Status: Card Terminated / Gateway Sinkholed

1. Executive Summary

On 16 September 2026, an automated fraud campaign targeting Romanian citizens was detected and triaged. Threat actors weaponized high-volume sponsored advertisements within the **TikTok** mobile platform, cloning the brand, promotional visuals, and e-commerce identity of **Media Galaxy** (Altex România S.A.). Victims clicking the sponsored link were funneled via the mobile in-app browser to mediagalaxy.voetbalshop-nlco.com, a localized fraudulent checkout portal designed to steal payment card data and Personally Identifiable Information (PII).

A debit of approximately **21 EUR** was executed against the victim's Revolut virtual card (funded through BCR - Banca Comercială Română) under the shell merchant descriptor '**morvethemi london**'. Immediately following payment authorization, the storefront switched to a deceptive maintenance screen ('The website is under maintenance'). Simultaneously, automated mail relays dispatched confirmation tokens ([229942-177457]) and password reset verification codes (586571) from spoofed domains (email.worvixglobal.com, info.mailapp-fly.com) to attempt secondary account takeover.

2. Technical Forensics & Attribution Findings

- A. DOM Reverse Engineering & Chinese Source Attribution:** Deep inspection of the landing page DOM exposed <html lang="zh-CN">, styling containers labeled module_login_default, and execution tracking variable window._CEDDE_ET. These signatures match commercial turnkey phishing/e-commerce SaaS software marketed on Chinese underground channels.
- B. Infrastructure Pivot to Backend C2:** Network probes against the Cloudflare proxy IP 104.16.145.247 hosting the landing subdomain uncovered a crucial configuration leak: direct HTTPS queries to ports 443 and 8443 returned an SSL certificate with Common Name: **cn: yiyangsaas.com**. WHOIS queries verified that yiyangsaas.com was registered via **eName Technology Co., Ltd.** in Yunnan, China, operating continuously since September 2023.
- C. Dual-Relay Phishing Architecture:** The campaign utilized two distinct mail infrastructures: (1) worvixglobal.com (registered at NameSilo in Feb 2025, using Zoho Mail MX), and (2) info.mailapp-fly.com (cryptographically signed via DKIM). In both flows, the Reply-To header was hardcoded to drop inboxes: MaryxBeckb96@gmail.com and brekerfurught@outlook.com.

3. Extracted Evidence Matrix (Desktop Screenshots)

File / Evidence ID	Artifact Type	Forensic Value & Extracted Intelligence
01-02_worvixglobal	Web Facade & WHOIS	Shell portal registered at NameSilo (2025-02-08) to establish aged domain reputation.
03-04_mailappfly	SMTP & DKIM Headers	DKIM-signed relay via info.mailapp-fly.com, Reply-To: MaryxBeckb96@gmail.com.
05-06_order_confirmation	Fake Invoice Token	Confirmation lure [229942-177457] from noreply@email.worvixglobal.com with Media Galaxy footer.
07-10_voetbalshop_landing	DOM & Chinese Lang	mediagalaxy.voetbalshop-nlco.com, lang='zh-CN', module_login, Cloudflare NS.
11-13_crt_wayback	Archival & SSL Certs	Zero historical Wayback captures; rapid wildcard SSL issuance via Let's Encrypt / Google Trust.
14_merchant_descriptor	Bank Descriptor Search	'morvethemi london' has zero registered business filings; shell billing aggregator.

19-22_yiyangsaas_pivot	Port 443 SSL & WHOIS	Direct IP query revealed cn: yiyangsaas.com; eName Technology registrant in Yunnan, China.
23-24_reset_password_ato	Secondary ATO Lure	Password reset code 586571 delivered to victim Moana Madalina with fake MEDIACALAXY logo.

4. Indicators of Compromise (IoCs)

Indicator	Type	Threat Role	Enforcement Action
mediagalaxy.voetbalshop-nlco.com	FQDN	Phishing Landing Subdomain	DNS Sinkhole (0.0.0.0)
voetbalshop-nlco.com	Domain	Base Infrastructure	Gateway Unbound Block
yyiangsaas.com	Domain	Backend C2 / Phishing SaaS	Outbound Egress Drop
worvixglobal.com	Domain	Attacker Shell & Mail Domain	DNS Sinkhole & Mail Filter
email.worvixglobal.com	FQDN	Order Fake Confirmation MTA	Quarantine at Mail Gateway
info.mailapp-fly.com	FQDN	ATO Verification Dispatcher	Quarantine at Mail Gateway
noreply@email.worvixglobal.com	Email	Phishing Sender	SMTP Sender Blacklist
noreply@info.mailapp-fly.com	Email	Phishing Sender	SMTP Sender Blacklist
MaryxBeckb96@gmail.com	Email	Attacker Drop Inbox	Report to Google Trust & Safety
brekerfurught@outlook.com	Email	Attacker Drop Inbox	Report to Microsoft Abuse
104.16.145.247 / 104.21.14.99	IPv4	Cloudflare Reverse Proxy IPs	Firewall Floating Reject Rule
morvethemi london	Descriptor	Fraudulent Bank Card Charge	Dispute / Chargeback Filing

5. Incident Response & Chargeback Playbook

Phase 1: Card Termination & Session Invalidation: The compromised Revolut virtual card was immediately frozen and permanently deleted through the Revolut application, preventing subsequent recurring billing attempts. All active Google/Gmail sessions for the victim were revoked, and FIDO2/Passkey authentication was enforced.

Phase 2: Bank Dispute Filing (Visa/Mastercard Chargeback): A formal claim under **Visa Dispute Condition 13.1 / Mastercard Reason Code 4853 (Merchandise Not Received / Fraudulent Merchant)** was submitted via Revolut in-app support. Documentation including the deceptive order token [229942-177457], offline maintenance status, and personal Gmail reply-to headers were attached to secure a full refund of the ~21 EUR transaction.

Phase 3: Perimeter Defense Integration on OPNsense Gateway (192.168.1.1):

- **Unbound DNS:** Deployed domains.txt to sinkhole queries to 0.0.0.0 across LAN/DMZ networks.
- **Suricata IDS/IPS:** Injected signatures sid:1000951-1000956 to log and drop HTTP/TLS requests to fraudulent hosts.
- **Egress Filtering:** Applied floating firewall rules blocking TCP outbound traffic to Cloudflare proxy endpoints 104.16.145.247.

Phase 4: Takedown & External Escalation: Abuse notices were filed with Cloudflare Trust & Safety, NameSilo Abuse, eName Technology, and the Romanian National Cyber Security Directorate (**DNSC** - alerts@dnsc.ro).

Incident Status: MITIGATED & SINKHOLED

Report Generated: 16 September 2026

Approved By: @stefanutc1 (Lead IR)